

Risk Assessment Framework

In subject area: [Computer Science](#)

A Risk Assessment Framework is defined as a structured approach or set of activities used to evaluate and manage risks in a systematic manner.

AI generated definition based on: [Information Security Risk Assessment Toolkit, 2013](#)

How useful is this definition?   

On this page

Chapters and Articles

You might find these chapters and articles relevant to this topic.

Chapter

Information Security Risk Assessment: A Practical Approach

[2013, Information Security Risk Assessment Toolkit](#)

Mark Talabis, Jason Martin

A Comparison of the Major Activities for the Four Frameworks Based on Activities

Looking at Table 2.21, one can see that in general, the major risk assessment frameworks have some measure of alignment based on several overarching activities or steps. Of course, one should note that although there are common concepts across frameworks, each framework may have a different way of accomplishing the assessment; however, the overall objective is still the same. The hybrid approach covered in this book is based on those common activities or steps.

Table 2.21. Comparison of Framework Activities



Identifying the asset and asset	Develop an Information Asset Profile	Identify asset at risk	System Characterization	Ident of As
---------------------------------	--------------------------------------	------------------------	-------------------------	-------------

Show more

View chapter

Explore book

[Read full chapter](#)

URL: <https://www.sciencedirect.com/science/article/pii/B9781597497350000026>

Review article

Cyber risk assessment in cloud provider environments: Current models and future needs

2019, Computers & Security

Olusola Akinrolabu, ... Steve New

2 Background and literature review

2.1 Risk assessment

[Risk Management](#) (RM) is the general process of managing risk to an [acceptable level](#) within an organisation and typically consists of two main stages known as risk assessment and risk treatment (Bojanc, 2013). Risk Assessment (RA) is a central part of [information security management](#), and it enables organisations to identify vulnerabilities and threats while also informing the choice of cost-effective controls (safeguards & countermeasures) to address potential threats (Cherdantseva et al., 2016). Ionita (2013) describes RA as a structured or semi-structured approach of analysing the security of a system, identifying weak spots, and selecting adequate controls.

According to the ISO/IEC 27005:2011 standard (ISO 27005, 2011), risk assessment consists of two processes, [Risk Analysis](#) & Risk Evaluation. RA involves a continuous iterative process which revolves around identifying, analysing, prioritising, mitigating and monitoring security risks. In assessing the risk of an IT system, several factors are taken into consideration, including identifying the asset, threat, vulnerability and impact. The objective of a risk assessment is to understand the existing system and environment and identify risks through analysis of the information/data collected, which helps organisations to make security decisions consistent

Show more

[Read full article](#)URL: <https://www.sciencedirect.com/science/article/pii/S0167404819301543>

Review article

Cyber risk assessment in cloud provider environments: Current models and future needs

2019, *Computers & Security*

Olusola Akinrolabu, ... Steve New

Abstract

Traditional frameworks for risk assessment do not work well for [cloud computing](#). While recent work has often focussed on the risks faced by firms adopting or selecting cloud services, there has been little research on how [cloud providers](#) might assess their own services. In this paper, we use an in-depth review of the extant literature to highlight the weaknesses of traditional risk assessment frameworks for this task. Using examples, we then describe a new risk assessment model (CSCCRA) and compare this against three established approaches. For each approach, we consider its goals, the [risk assessment process](#), decisions, the scope of the assessment and the way in which risk is conceptualised. This evaluation points to the need for dynamic models specifically designed to evaluate cloud risk. Our suggestions for future research are aimed at improving the identification, assessment, and mitigation of inter-dependent cloud risks inherent in a defined supply chain.

[View article](#)[Read full article](#)URL: <https://www.sciencedirect.com/science/article/pii/S0167404819301543>

Review article

Cyber risk assessment in cloud provider environments: Current models and future needs

2019, *Computers & Security*

Olusola Akinrolabu, ... Steve New

2.1 Risk assessment

[Risk Management](#) (RM) is the general process of managing risk to an [acceptable level](#) within an organisation and typically consists of two main stages known as risk assessment and risk treatment (Bojanc, 2013). Risk Assessment (RA) is a central part of [information security management](#), and it enables organisations to identify



potential threats (Cherdantseva et al., 2016). Ionita (2013) describes RA as a structured or semi-structured approach of analysing the security of a system, identifying weak spots, and selecting adequate controls.

According to the ISO/IEC 27005:2011 standard (ISO 27005, 2011), risk assessment consists of two processes, [Risk Analysis](#) & Risk Evaluation. RA involves a continuous iterative process which revolves around identifying, analysing, prioritising, mitigating and monitoring security risks. In assessing the risk of an IT system, several factors are taken into consideration, including identifying the asset, threat, vulnerability and impact. The objective of a risk assessment is to understand the existing system and environment and identify risks through analysis of the information/data collected, which helps organisations to make security decisions consistent with their [risk management](#) strategy, despite the level of uncertainty inherent in the evaluation process (Ross, 2012). Risk assessments are conducted to inform decision-makers and support risk responses, either as part of a security audit, compliance initiative, or to support security budget decisions (Ionita, 2013; Ross, 2012). Therefore, in assessing risks, it is practical to implement a risk assessment framework that employs a rigorous process in determining the risk factors and promotes increased objectivity through the use of controlled experimentation. Also, the process followed by the risk assessment model in evaluating initial risks and informing security decisions should be repeatable, understandable, and traceable.

Overall, the main result of a risk assessment exercise is the quantitative or qualitative evaluation of the possible impact of threat

[View article](#)[Read full article](#)

URL: <https://www.sciencedirect.com/science/article/pii/S0167404819301543>

Chapter

Information Security Risk Assessment: A Practical Approach

2013, [Information Security Risk Assessment Toolkit](#)

Mark Talabis, Jason Martin

Introduction

There has been quite a bit written about information [security risk assessments](#). In fact, there are numerous published information [security risk assessment](#) frameworks and numerous books about the subject that are currently in circulation. But with so many frameworks to choose from why do organizations continue to struggle with the concept?



based on the [foundational concept](#) of risk as was discussed in Chapter 1. The real difficulty lies in the implementation of these frameworks. Except for a few of the frameworks, most focus on concepts and principles represented in many cases as various risk formulas. What is almost universally missing is a practical approach on how to bring these frameworks into the workplace. For example, it is easy to say to someone that they need to identify assets and threats, but how do you actually go about doing this in an organization?

This chapter will attempt to address the gap between conceptual risk frameworks and actual workplace implementation. Coverage over major [information security risk](#) assessment frameworks such as OCTAVE, FAIR, NIST SP800-30, and ISO 27005 will be provided as well as a brief introduction to some lesser-known frameworks. This chapter will also introduce the reader to a hybrid approach to

[View chapter](#)[Explore book >](#)[Read full chapter](#)URL: <https://www.sciencedirect.com/science/article/pii/B9781597497350000026>

Chapter

Information Security Risk Assessment: A Practical Approach

[2013, Information Security Risk Assessment Toolkit](#)

Mark Talabis, Jason Martin

A Primer on Information Security Risk Assessment Frameworks

First and foremost, we need to understand what a framework is. A framework is some form of logical structure to organize information or activities. Thus, an information [security risk assessment](#) framework provides the logical structure or model to guide a user through the process of executing an [information security risk](#) assessment. Typically, these frameworks won't go into implementation details but will focus on [foundational concepts](#) associated with risk elements, high-level activities, formulas, and decision matrices, all of which are components essential to successfully conducting an information security risk assessment within an organization.

In this section, we will be focusing on the major information security risk assessment frameworks commonly used within the United States such as OCTAVE, FAIR, NIST, and ISO27005; however, we will also provide information on some additional frameworks and



This section is meant to be a primer so it will be a high-level overview instead of a detailed discussion regarding the different

Show more

View chapter

Explore book

[Read full chapter](#)

URL: <https://www.sciencedirect.com/science/article/pii/B9781597497350000026>

Chapter

Information Security Risk Assessment: A Practical Approach

2013, [Information Security Risk Assessment Toolkit](#)

Mark Talabis, Jason Martin

Our Risk Assessment Approach

The goal of this book is to be able to successfully complete a quick and defensible risk assessment project. When we talk about implementing a risk assessment project, these are organizational and project activities that would encapsulate the [frameworks and methodologies](#) discussed to use both an efficient and structured approach to collect, analyze and evaluate data. We have written this approach with five main considerations:

1. *The approach will be practical*—The main goal for the approach provided in this book is to provide something that will bridge the frameworks and methodologies into something that can be easily understood, executed, and defended. Risk assessment frameworks are structured based on risk concepts. In our approach, we will be encapsulating these concepts into specific activities. For example, where FAIR recommends the activity of “Identify Scenario Components,” our methodology will break it down into much more specific organizational activities such as “Conduct scoping meetings,” “Conduct executive surveys,” “Prepare an asset spreadsheet,” as well as others.
2. *The approach will be based on common denominators*—In the risk assessment primer provided in this chapter, you have seen that there are quite a few risk assessment frameworks out there. This chapter has provided a brief description of the major risk

Show more

View chapter

[Read full chapter](#)URL: <https://www.sciencedirect.com/science/article/pii/B9781597497350000026>

Review article

Cyber security readiness in the South Australian Government

2015, *Computer Standards & Interfaces*

Brenton Borgman, ... Kim-Kwang Raymond Choo

3.3 Risk assessment

Risk assessments aim to identify, prioritize, and quantify risk to organisational operations, and organisational assets, resulting from the loss of confidentiality, integrity, or availability of information or [information systems](#). This subsequently seeks to reflect the potential adverse impacts that may occur to organisational operations, information assets, and the operation or use of information systems [42].

As stipulated in the SA Government (PSMF), the Chief Executive of an entity is accountable for the development and management of an Entity's Security Plan which must be developed to manage the entity's security risks and should be based on a security policy that supports the Agency's goals and resources. The security risks are to be managed in accordance with AS/NZS ISO 31000:2009 [30] and the principles of the SA Government [Risk Management](#) Policy Statement. SA government entities are required to develop a single risk assessment mechanism that is used for multiple purposes within an entity and its importance cannot be understated.

13 participants reportedly had established risk assessments within their entities. Of these risk assessments, the participating entities acknowledged the importance of the risk assessment process but confirmed that not all assessments incorporate information asset and data as a key consideration. This is currently being readdressed in order to realign and comply with [ISMS requirements](#). The ITSA participants acknowledged that currently some of the entity risk assessments under review were being realigned following the implementation of the SA Government [ISMF](#). This will incorporate additional security considerations as part of the baseline for the ISMS and classification of data. The remaining three participants confirmed that their entities are in the context of developing a risk assessment framework specific to their entity to assist in the development and implementation of the ISMS.

Further when assessing the respective responses from the respective ASE and ITSA, one ASE participant was reportedly unaware or

[View article](#)[Read full article](#)



Implementation Experiences from Smart Grid Security Applications and Outlook on Future Research

2015, Smart Grid Security

Stylianios Basagiannis, ... Menouer Boubekeur

10.3.3 Advanced Security Analytics

The [primary objective](#) of cyber-security risk assessment is to identify vulnerabilities and threats, and determine their impact. Risk assessment provides a structured process that identifies risks in terms of consequences, their probabilities and their effect on objectives, either qualitatively using threat graphs and game-theoretic models, or quantitatively by using metrics representing threat probabilities. There are many conflicting risk assessment methodologies, standards and tools (SISRAM, 2012). A repository is maintained by the European Network and Information Security Agency (ENISA), but none of those have a standard common framework to ensure a minimum level of harmonization, which prevents automation of security analysis methodologies. Current risk assessment frameworks are based on those designed for IT and traditional power [grid systems](#) such as those described by National Institute of Standards and Technology (NIST) (NIST, 2014), North-American Electric Reliability Corporation (NERC) (NERC, 2002), International Society of Automation (ISA) standards (ISA, 2007), thus not catering to the idiosyncrasies of a smart grid. This makes it an arduous task to apply one or more of these methods and techniques for any realistic risk assessment.

It is necessary to merge both cyber and [power systems](#) security approaches for risk assessment of a smart grid. The existing standards and best practices should be evolved to employ tools that provide significant insights into threats and security strategies, such as attack graphs and game-theoretic models, in tandem with

[View chapter](#)

[Explore book](#) >

[Read full chapter](#)

URL: <https://www.sciencedirect.com/science/article/pii/B9780128021224000109>

Chapter

Information Security Risk Assessment: A Practical Approach

2013, Information Security Risk Assessment Toolkit



Control Recommendations

In some risk assessment frameworks, the assessment is completed once a risk rating is provided; however, since NIST SP800-30 is a [risk management framework](#), it takes into account the remediation and mitigation aspect in its overall process and it's worth remembering that control recommendations are part of the [risk assessment report](#).

Once the risk rating is derived from the previous step, control recommendations which are provided to mitigate the risks are identified. NIST also recommends performing a cost benefit analysis to make sure that the cost of control implementation does not exceed the estimated loss associated with a given event but it does not provide specific guidance on this process.

[View chapter](#)[Explore book >](#)[Read full chapter](#)

URL: <https://www.sciencedirect.com/science/article/pii/B9781597497350000026>

Related terms:

[Monte Carlo Simulation](#), [Smart Grid](#),
[Dempster-Shafer Theory](#),
[Convolutional Neural Network](#), [Bayesian Model](#),
[Supply Chain](#), [Federal Agency](#),
[Information Security Risk](#),
[Security Risk Assessment](#),
[Uncertainty Estimation](#).

Recommended publications



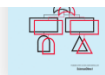
Computers & Security

Journal



Expert Systems with Applications

Journal



Journal



Internet of Things

Journal

Featured Authors

Torabi, S. Ali

University of Tehran, Tehran, Iran

Citations: **11,124** *h*-index: **55** Publications: **87**

Zhou, Jianying

Singapore University of Technology and Design, Singapore City,
Singapore

Citations: **9,393** *h*-index: **47** Publications: **28**

Currie, Wendy L.

Audencia, Nantes, France

Citations: **3,816** *h*-index: **34** Publications: **44**

Madria, Sanjay Kumar

College of Engineering and Computing, Rolla, United States

Citations: **3,499** *h*-index: **26** Publications: **39**



ELSEVIER

All content on this site: Copyright © 2025 Elsevier B.V., its licensors, and contributors. All rights are reserved, including those for text and data mining, AI training, and similar technologies. For all open access content, the relevant licensing terms apply.

